

Atividade – Classificação de Ativos

Aluno: Lucas Henrique Dias de Medeiros.

Professor: Carlos Henrique.

Objetivo: Identificar, classificar e priorizar ativos de tecnologia da informação considerando os princípios de Confidencialidade, Integridade e Disponibilidade (CID), relacionando a proteção dos ativos às práticas de DevOps e DevSecOps.

Parte 1 – Identificação dos Ativos

Ativo	O que é?	Para que serve?	Quem utiliza?
Banco de dados de alunos	Sistema de armazenamento que guarda dados acadêmicos e pessoais dos estudantes (matrícula, notas, dados cadastrais).	Gerenciar e disponibilizar informações acadêmicas e pessoais para os processos da instituição	Professores, coordenação pedagógica, setor administrativo e a própria plataforma.
Sistema de autenticação	Componente responsável por validar a identidade dos usuários no acesso à plataforma (login, senha, tokens).	Garantir que apenas usuários autorizados acessem os sistemas e recursos.	Alunos, professores, funcionários e os sistemas internos que dependem de login.
Código-fonte	Conjunto de arquivos de programação que implementam as funcionalidades da plataforma.	Construir, manter e evoluir as funcionalidades do sistema.	Desenvolvedores e equipe de DevSecOps.
Pipeline CI/CD	Conjunto de processos automatizados de integração e entrega contínua de software.	Automatizar build, testes e deploy da aplicação de forma rápida e padronizada	Equipe de desenvolvimento e DevSecOps.
Servidor de produção	Infraestrutura onde a aplicação roda em ambiente real, acessível aos usuários finais.	Hospedar e executar a plataforma que é efetivamente utilizada pelos usuários.	Equipe de infraestrutura.
Ambiente de desenvolvimento	Infraestrutura utilizada para desenvolver e testar novas funcionalidades antes da produção.	Permitir a criação e os testes iniciais de código sem impactar o ambiente real.	Desenvolvedores.
Repositório Git	Sistema de controle de versão que armazena o histórico e as versões do	Permitir versionamento, colaboração e rastreabilidade das alterações no código.	Desenvolvedores e equipe de DevSecOps.

	código-fonte.		
Sistema de pagamentos	Módulo responsável por processar transações financeiras, como mensalidades e taxas.	Processar cobranças e pagamentos realizados pelos usuários da plataforma.	Alunos/responsáveis financeiros e setor financeiro.
Logs da aplicação	Registros de eventos, erros e atividades gerados pelo sistema durante sua execução.	Permitir auditoria, rastreabilidade e diagnóstico de problemas e incidentes.	Equipe de segurança, DevOps e auditoria.
Backup do Banco de Dados	Cópia de segurança dos dados armazenados no banco de dados.	Permitir a recuperação de dados em caso de perda, corrupção ou incidente.	Equipe de infraestrutura e DevOps.
API de integração	Interface que permite a comunicação entre a plataforma e outros sistemas internos ou externos.	Integrar a EduTech com sistemas parceiros (sistemas acadêmicos, gateways de pagamento).	Sistemas parceiros e desenvolvedores.
Sistema de e-mail	Serviço de comunicação eletrônica institucional.	Enviar notificações, comunicados e mensagens de recuperação de acesso	Alunos, professores e funcionários.
Ambiente de testes	Infraestrutura destinada à validação de funcionalidades antes de irem para produção.	Testar novas versões do sistema e identificar bugs e vulnerabilidades previamente.	Equipe de QA e desenvolvedores.
Chaves e secrets da aplicação	Credenciais sensíveis, como senhas, tokens de API e chaves de criptografia usadas pela aplicação.	Autenticar e autorizar a comunicação segura entre serviços e sistemas.	A própria aplicação, o pipeline CI/CD e a equipe de desenvolvimento.
Documentação técnica da infraestrutura	Registros descritivos da arquitetura, configurações e processos da infraestrutura de TI.	Orientar a manutenção, o onboarding de novos membros e a resposta a incidentes.	Equipe técnica: DevOps, infraestrutura e segurança.

Parte 2 – Segurança e DevSecOps

Ativo	Risco Principal	Medida de proteção	Prioridade
Banco de dados de alunos	Vazamento de dados pessoais (violação de LGPD) e acesso não autorizado.	Criptografia em repouso e em trânsito; controle de acesso (IAM) com menor privilégio; monitoramento de acessos.	Alta.
Sistema de autenticação	Comprometimento de credenciais e ataques de força bruta.	MFA; política de senhas fortes; hash nas credenciais; monitoramento de tentativas de login.	Alta.
Código-fonte	Vazamento de propriedade intelectual e inserção de vulnerabilidades no código.	SAST e SCA no processo de desenvolvimento; controle de acesso ao repositório; revisão de código.	Alta.
Pipeline CI/CD	Injeção de código malicioso e exposição de secrets durante o build/deploy.	Gestão de secrets; SAST/DAST/SCA integrados ao pipeline; controle de acesso; assinatura de artefatos.	Alta.
Servidor de produção	Indisponibilidade (ataques DDoS) e exploração de vulnerabilidades do sistema.	WAF; segmentação de rede; monitoramento contínuo/SIEM; gestão de patches; backups.	Crítica.
Ambiente de desenvolvimento	Uso de dados reais sem proteção e configurações inseguras que podem migrar para produção.	Segregação de ambientes; uso de dados mascarados /fictício; controle de acesso restrito.	Média.
Repositório Git	Acesso não autorizado e	MFA; proteção de branches; varredura	Alta.

	exposição de secrets commitados no histórico do código	automática de secrets (secret scanning); SCA.	
Sistema de pagamentos	Fraude financeira e vazamento de dados de cartão e transações.	Criptografia forte; conformidade com PCI-DSS; tokenização de dados; monitoramento antifraude; WAF.	Crítica.
Logs da aplicação	Adulteração de registros e exposição de dados sensíveis nos próprios logs	Logs centralizados; SIEM; garantia de integridade (hash/assinatura); controle de acesso e retenção definida.	Média.
Backup do banco de dados	Corrupção, perda do backup ou acesso não autorizado às cópias de segurança.	Criptografia dos backups; testes periódicos de restauração; armazenamento redundante (estratégia 3-2-1).	Alta.
API de integração	Exposição de dados por endpoints mal protegidos e ataques de injeção.	Autenticação forte; rate limiting; validação de entrada; WAF; testes DAST.	Alta.
Sistema de e-mail	Phishing, spoofing e comprometimento de contas institucionais.	Configuração de SPF/DKIM/DMARC; MFA; filtros antispam/antiphishi ng; monitoramento de envios.	Média.
Ambiente de testes	Uso de dados sensíveis reais sem proteção e configurações inseguras.	Anonimização/masc aramento de dados; segregação de ambientes; controle de acesso restrito.	Média.
Chaves e secrets da	Vazamento de	Cofre de segredos;	Crítica.

aplicação	secrets e comprometimento total do sistema.	criptografia; rotação periódica; menor privilégio; scanning automatizado.	
Documentação técnica da infraestrutura	Vazamento de informações que facilitam ataques ao revelar a arquitetura da infraestrutura.	Controle de acesso restrito; criptografia de armazenamento; classificação de sigilo do conteúdo.	Média.